

Relatório de Auditoria de Segurança — Pack de Sites Manager

Data: 02/09/2026

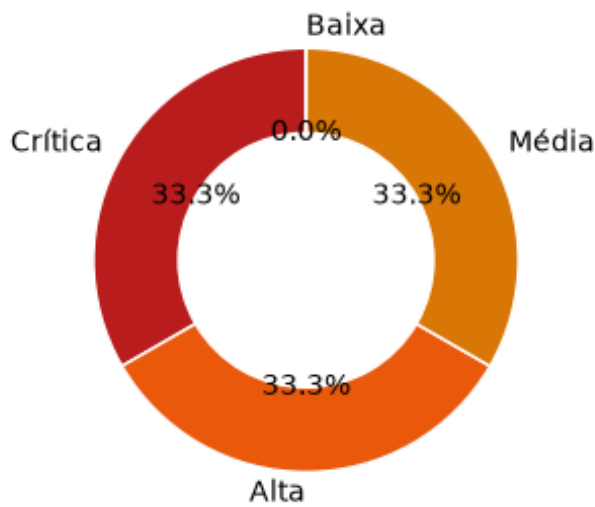
Escopo: plugins/pdsm-plugin e plugins/pdsm-client

Nota Metodológica:

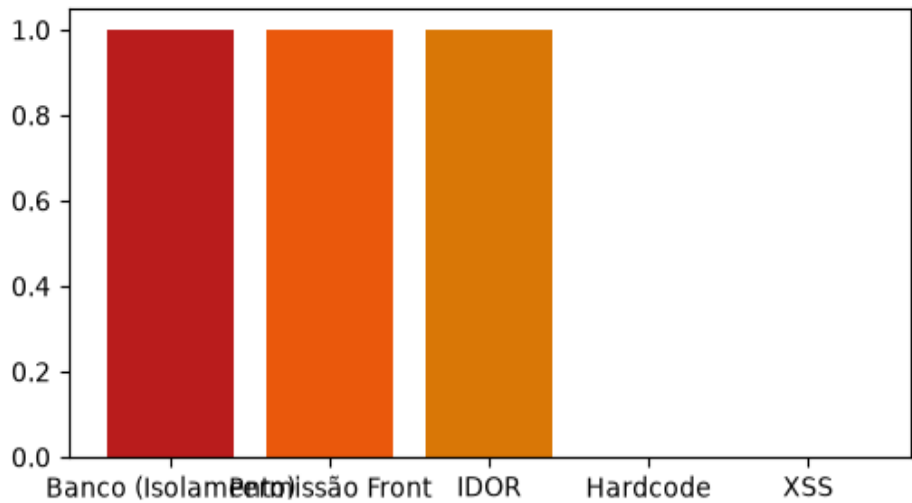
Cada categoria foi mapeada para a stack WordPress (PHP). Como o projeto não possui ORM moderno ou RLS no banco, o foco do isolamento recaiu sobre filtros de queries SQL e chamadas de API (IDOR). O frontend em WP Dashboard (class-admin.php) foi cruzado com os endpoints API de backend correspondentes para testar a equivalência das restrições de permissão.

Resumo Executivo

Distribuição por Severidade (Rosca)



Distribuição por Categoria



Pontos Fortes e Fracos

Pontos Fortes:

- [XSS e Inputs Vacinados] A saída HTML do class-admin.php sanitiza perfeitamente inputs usando esc_html, esc_attr e esc_url. Não foram encontrados vazamentos do master key via payload sujo.
- [Hardcode Evitado] Não há secrets absolutos chumbados. E o endpoint anti-SSRF rejeita tráfego local.

Pontos Fracos:

- Falha grave de isolamento (Tenant) entre Sites na API de listagem.
- Faltam verificações de capacidades (capabilities) equivalentes no GET/POST da gestão de sites, delegando a permissão puramente ao conhecimento da Chave API.

Tabela de Achados

Severidade	Arquivo:Linha	Descrição
CRÍTICA	class-api.php:129	A rota GET /sites exibe TODOS os sites, sem filtrar a qual cliente
ALTA	class-api.php:132	A rota POST /sites permite adicionar sites apenas conhecendo um
MÉDIA	class-api.php:121	A rota GET /jobs/<id> sofre de IDOR, não checa se o ID pertence
INFORMATIVA	class-installer.php	A Click API pk_84036951_WUKHOM60E01ALQMM3RMOY8D2O

Recomendações e Issues para o GitHub

--- ISSUE 1 ---

[Segurança] Vazamento de Tenant (Falta de Isolamento) na listagem de Sites e Jobs

Labels: security, critica

Descrição:

A API expõe `get_sites()` e `get_job_status($id)` aceitando qualquer requisição que venha com uma X-API-Key válida de qualquer site. O sistema não filtra a query SQL ou o `get_option` pelo ID do inquilino (site chamador).

Evidência:

`plugins/pdsm-plugin/includes/class-api.php:129`

```
public function get_sites() { return rest_ensure_response($this->site_manager->get_sites()); }
```

Impacto: Um cliente compromete a privacidade de todos os demais.

Sugestão de correção: Retornar apenas os sites cujo array contenha a `api_key` informada no header.

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

[Segurança] Falta de verificação de permissão equivalente na criação de Sites

Labels: security, alta

Descrição:

O frontend usa o `capability manage_options` para renderizar o form, mas o backend (API POST `/sites`) apenas verifica `auth_hmac_rbac` sem aplicar um `capability add_sites`.

Evidência:

`plugins/pdsm-plugin/includes/class-api.php:132` (Não há RBAC imposto para POST `/sites`).

--- FIM ISSUE 2 ---